

HOW TO PERFORM THIRD-PARTY VENDOR RISK ASSESSMENTS

*A practical guide to due diligence, contracts, evidence, monitoring, incidents,
and supply-chain security*

Alberto (Al) Leiva

Version 1.0 - July 2026

Human safety and fairness come first. This manual is for lawful, authorized, and defensive use. Vendor assessments should be fair, evidence-based, proportionate to risk, and respectful of confidentiality.

1. Purpose and outcomes

- Identify how a supplier, service provider, subcontractor, software product, cloud platform, or AI provider could affect the organization.
- Decide whether the relationship is acceptable, requires remediation, needs stronger contract terms, or should not proceed.
- Create a repeatable record of scope, evidence, findings, decisions, owners, and review dates.
- Apply deeper diligence to higher-risk relationships without creating unnecessary barriers for low-risk vendors.

2. Program governance

- Assign executive sponsorship and clear ownership across security, privacy, legal, procurement, compliance, business, and technology teams.
- Define an approved methodology, risk tiers, evidence requirements, escalation routes, exception authority, and review cadence.
- Maintain independence between the business sponsor and the person approving material residual risk.
- Measure timeliness, overdue assessments, unresolved critical findings, concentration risk, and incident performance.

3. Build the vendor inventory

- Record the vendor's legal name, parent company, service, business owner, contract owner, countries, data handled, integrations, subcontractors, renewal date, and termination requirements.
- Include free software, open-source components, marketplace applications, consultants, data brokers, AI services, and shadow IT.
- Link vendors to business services, systems, data sets, regulations, and continuity plans.
- Mark inactive, duplicate, acquired, divested, and terminated suppliers accurately.

4. Triage and risk tiering

- Tier vendors before sending a long questionnaire.
- Consider data sensitivity, privileged access, network connectivity, transaction authority, business criticality, user population, geographic exposure, AI use, subcontractors, and ease of replacement.
- Use a simple inherent-risk score, but allow professional judgment and documented overrides.
- Do not treat a small vendor as low risk merely because it has few employees.

5. Scope the assessment

- Define the exact product, service, environment, data flow, interfaces, locations, and contract under review.
- State whether the review covers the company, one product, a hosted service, a deployment region, or a specific processing activity.

- Identify what is excluded and why.
- Set evidence dates and reject stale evidence when it no longer represents the service.

6. Due diligence evidence

- Prefer evidence over unsupported yes-or-no answers.
- Possible evidence includes SOC reports, ISO certificates, penetration-test summaries, policies, architecture diagrams, data-flow diagrams, vulnerability reports, business continuity tests, incident-response exercises, privacy assessments, and secure-development records.
- Verify the scope, period, issuing organization, qualifications, exceptions, management responses, and complementary customer controls.
- Protect vendor-confidential evidence and limit internal access.

7. Security domains to assess

- Governance and risk management.
- Identity, privileged access, and authentication.
- Data protection, encryption, retention, and deletion.
- Network and cloud security.
- Secure development, vulnerability management, and software supply chain.
- Logging, monitoring, detection, and incident response.
- Business continuity, disaster recovery, and resilience.
- Privacy, regulatory, and contractual obligations.
- Subcontractors and fourth parties.
- AI systems, models, agents, training data, RAG, and automated decisions when applicable.

8. Questionnaire design

- Ask questions that can change a decision or control requirement.
- Use conditional questions so low-risk vendors do not receive irrelevant sections.
- Request one clear item of evidence for each material assertion.
- Avoid copying hundreds of controls without explaining applicability.
- Allow the vendor to explain compensating controls and planned remediation.
- Track question source, framework mapping, evidence, reviewer conclusion, and expiration date.

9. Review SOC reports and certifications

- Confirm that the report or certificate covers the service being purchased.
- Review the audit period, opinion, scope limitations, carve-outs, exceptions, subservice organizations, and complementary user-entity controls.
- Do not treat a clean report as proof that every risk is addressed.
- Confirm the certificate is valid and issued by an appropriate accredited body where applicable.
- Request bridge letters or more recent evidence when the coverage period has ended.

10. Cloud, software, and open-source risk

- Identify hosting model, regions, tenancy, administrative access, backup, encryption, logging, and customer security responsibilities.
- Review software bills of materials when appropriate, dependency management, code-signing, release integrity, and vulnerability disclosure practices.
- Assess how rapidly critical vulnerabilities are triaged and remediated.
- Determine whether unsupported components, end-of-life products, or unmaintained libraries are present.
- Document customer configuration duties so risk is not incorrectly assigned only to the vendor.

11. AI-provider and AI-service risk

- Identify models, providers, data uses, prompt retention, training use, subprocessors, geographic processing, content controls, human oversight, and incident processes.
- Determine whether confidential or personal information may be used to improve shared models.
- Assess prompt injection, data leakage, insecure agents, tool access, RAG authorization, model updates, and output reliability.
- Require transparency about material model or service changes.
- Define prohibited uses and approval requirements for high-impact decisions.

12. Contract and procurement controls

- Translate important risk decisions into enforceable contract language.
- Address security requirements, privacy, confidentiality, data location, subcontractors, audit rights, incident notification, cooperation, vulnerability remediation, continuity, insurance, records, deletion, and termination assistance.
- Define measurable service levels and remedies where appropriate.
- Ensure contract obligations flow down to relevant subcontractors.
- Do not rely on a questionnaire when the contract does not require the promised controls.

13. Findings and risk ratings

- Write findings as a condition, risk, evidence, impact, and required action.
- Separate inherent risk, control effectiveness, residual risk, and business acceptance.
- Use severity criteria consistently, but consider exploitability, data sensitivity, business impact, legal duties, and concentration.
- Do not inflate every gap to high risk.
- Record uncertainty when evidence is incomplete.

14. Remediation and exceptions

- Assign an owner, action, target date, evidence requirement, and review date.
- Use interim safeguards when permanent remediation will take time.

- Escalate overdue high-risk actions.
- Require formal acceptance for material residual risk.
- Set expiration dates for exceptions and reassess before renewal.
- Close findings only after reviewing evidence.

15. Continuous monitoring

- Monitor security ratings cautiously; use them as signals rather than final conclusions.
- Track breaches, ownership changes, acquisitions, legal actions, certificate status, vulnerabilities, service outages, geographic changes, subcontractors, and material product changes.
- Reassess after incidents, major architectural changes, expanded data use, new integrations, or contract renewal.
- Keep review frequency proportional to risk.

16. Vendor incident response

- Maintain current contacts and escalation paths.
- Define notification timelines and required incident information in contracts.
- Coordinate containment, evidence preservation, regulatory analysis, customer communication, recovery, and lessons learned.
- Determine whether access, tokens, integrations, or data transfers should be suspended.
- Track the vendor's corrective actions and validate closure.

17. Offboarding and termination

- Disable accounts, tokens, integrations, VPN access, API keys, certificates, and administrative access.
- Recover organizational assets and confirm data return or secure deletion.
- Preserve records required for legal, regulatory, or audit purposes.
- Transfer knowledge, configurations, and operational dependencies.
- Remove the vendor from inventories and monitoring tools only after closure is verified.

18. Reporting and metrics

- Report vendor population by risk tier, assessment status, overdue reviews, open findings, accepted risks, incidents, concentration, and critical dependencies.
- Show trends rather than isolated counts.
- Distinguish risk owned by the vendor from customer responsibilities.
- Provide executives with decisions and exposure, not only questionnaire completion rates.

19. 30/60/90-day implementation plan

- Days 1-30: define governance, inventory critical vendors, create tiering criteria, identify overdue high-risk relationships, and establish minimum contract clauses.

- Days 31-60: launch risk-based assessments, centralize evidence, create finding and exception workflows, and identify concentration and fourth-party risks.
- Days 61-90: implement continuous monitoring, incident exercises, renewal gates, metrics, and periodic quality reviews.

20. Practical assessment workflow

1. Receive the request and identify the business owner.
2. Complete inherent-risk triage.
3. Define scope and evidence requirements.
4. Collect and review evidence.
5. Interview the vendor when material questions remain.
6. Document findings and residual risk.
7. Agree remediation and contract controls.
8. Obtain approval or risk acceptance.
9. Record monitoring and reassessment dates.
10. Reassess at renewal or after material change.

21. Sample risk-tier criteria

Tier	Typical characteristics	Review
Critical	Privileged access, highly sensitive data, essential operations, transaction authority, major concentration	Full assessment, contract review, executive approval, annual or event-driven reassessment
High	Sensitive data, production integration, important service, significant subcontractors	Detailed evidence review and annual reassessment
Moderate	Limited confidential data or business dependency	Focused questionnaire and periodic reassessment
Low	No sensitive data, no connectivity, easily replaceable	Basic verification and lightweight review

22. Sample finding

Element	Example
Condition	The vendor does not require MFA for privileged production administration.
Evidence	Administrative access policy and vendor interview dated July 2026.
Risk	A stolen password could permit unauthorized production access and data exposure.
Required action	Implement phishing-resistant MFA for privileged accounts and provide evidence.
Interim control	Restrict access by network, monitor logins, and

	rotate credentials.
Owner / due date	Vendor Security Lead / 60 days

23. Production checklist

- ☐ Vendor inventory entry completed
- ☐ Business owner and contract owner identified
- ☐ Inherent-risk tier approved
- ☐ Scope and data flow documented
- ☐ Evidence current and applicable
- ☐ SOC/ISO scope and exceptions reviewed
- ☐ Security, privacy, continuity, and incident risks assessed
- ☐ Subcontractors and concentration reviewed
- ☐ AI risk reviewed where applicable
- ☐ Contract clauses approved
- ☐ Findings assigned and tracked
- ☐ Residual risk accepted by authorized owner
- ☐ Monitoring and reassessment scheduled
- ☐ Offboarding requirements documented

24. Official references

- NIST SP 800-161 Rev. 1, Cybersecurity Supply Chain Risk Management Practices: <https://csrc.nist.gov/pubs/sp/800/161/r1/upd1/final>
- NIST SP 1326, C-SCRM Due Diligence Assessment Quick-Start Guide: <https://csrc.nist.gov/pubs/sp/1326/final>
- NIST Cybersecurity Framework 2.0: <https://www.nist.gov/cyberframework>
- CISA Supply Chain Resources: <https://www.cisa.gov/topics/cyber-threats-and-advisories/information-and-communications-technology-supply-chain-security>
- ISO/IEC 27036-1:2021 Supplier Relationships: <https://www.iso.org/standard/82905.html>
- ISO/IEC 27036-2:2022 Supplier Relationship Requirements: <https://www.iso.org/standard/82060.html>
- ISO/IEC 27036-3:2023 Hardware, Software, and Services Supply Chain Security: <https://www.iso.org/standard/82890.html>

License

Copyright © 2026 Alberto (Al) Leiva. Licensed under CC BY-NC-SA 4.0.